

Solution of Lecture 1

Tutorial Sheet - Lecture 1

Computer Security

Part A

1. Which of the following is *not* one of the fundamental goals of computer security?

Correct Answer: C. Repudiation

Explanation: The primary, classic goals of computer security are often summarized as **CIA** (Confidentiality, Integrity, Availability). Other important security properties include authentication, authorization, and accountability. *Repudiation* (or its opposite, **non-repudiation**) is an important concept but not typically listed as one of the *foundational* goals.

2. Which statement best characterizes the principle of *authentication* in computer security?

Correct Answer: C. Confirming the identity or genuineness of an entity or data source

Explanation:

- **A** (Ensuring data are unaltered) is Integrity.
- **B** (Ensuring only authorized users can access resources) is Authorization.
- **C** (Correct) describes what Authentication actually does –verifying identity.
- **D** (Guaranteeing system availability) is Availability.

3. Which of the following adversary attributes deals primarily with the *financial resources* at an attacker's disposal?

Correct Answer: D. Funding Level

Explanation:

- **Objectives** = attacker goals.
- **Methods** = techniques used.
- **Capabilities** = skill set, knowledge, or computational power.

- **Funding Level** = amount of money or financial backing they have, which directly influences the scale of their operations.
4. In threat modeling, which approach specifically uses a visual hierarchical structure where the root node is the overall attack goal and the leaves represent methods to achieve it?
- Correct Answer:** B. Attack Trees
- Explanation:**
- **Attack Trees** start with a top-level goal (root) and branch out into different possible ways (children nodes) to achieve that goal.
 - **STRIDE, Diagram-Driven Modeling, and Checklists** follow different methods of enumerating and analyzing threats.
5. In the risk equation $R = T \times V \times C$, the term V refers to:
- Correct Answer:** B. The vulnerability level of a system
- Explanation:**
- **T** = Threat probability
 - **V** = Vulnerability (likelihood the threat will succeed if attempted)
 - **C** = Cost (impact if the threat succeeds)

Part B

1. Real-World Incidents

Sample Answer (WannaCry):

- **Nature of the Attack:** WannaCry was a ransomware attack exploiting a Microsoft Windows vulnerability (EternalBlue) to spread rapidly across networks. Once infected, it encrypted user data and demanded Bitcoin payment for decryption.
- **Broader Impact:** The attack affected over 230,000 computers in more than 150 countries. Organizations like the UK's National Health Service (NHS) faced significant operational disruptions, canceled medical appointments, and reputational damage. The financial impact was substantial for organizations needing to restore systems and manage data recovery.

- **Significance:** WannaCry underscored how quickly a ransomware campaign could propagate worldwide and highlighted the importance of timely patching. It represented a milestone in global awareness of ransomware and the vulnerabilities inherent in outdated systems.

Note: You can apply a similar structured approach if you chose NotPetya, Stuxnet, or TRITON.

2. **Security Policy and Attacks**

Key Points:

- A **security policy** defines what is allowed and disallowed in a system. It includes rules and guidelines that enforce confidentiality, integrity, availability, etc.
- An **attack** is a deliberate action intended to violate the security policy. When an attacker exploits a vulnerability, they cause a deviation from the secure state defined by the policy.
- **Example of Policy:** An organization's policy might state that only authorized personnel can access sensitive financial data. A policy violation (e.g., an unauthorized user gaining access) leads to a non-secure state where the confidentiality and integrity of that data are compromised.

Sample Answer:

"A security policy is the formal expression of what actions are permitted and prohibited on a system. An attack occurs when an adversary takes steps to force a violation of these rules, resulting in a non-secure state. For instance, a company might enforce a policy that only employees with certain clearance levels can view customer financial records. If a malicious outsider (or even an insider without clearance) obtains access, that violation undermines confidentiality—moving the system into a non-secure state."

3. **Threat Modeling Methods**

Compare: Diagram-Driven vs. STRIDE

- Diagram-Driven Modeling

- How it Identifies Threats:

- You draw detailed architectural diagrams highlighting system components, data flows, and trust boundaries.
- You ask, "What could go wrong at each boundary or component?"

- Advantages:

- Helps visualize complex systems.
- Good for discovering unknown issues by walking through data flows and user actions.

- Disadvantages:

- Can be time-consuming for large systems.
- Quality relies on the accuracy and completeness of the diagram.

- STRIDE

- How it Identifies Threats:

1. Uses six predefined threat categories: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Escalation of Privilege.
2. You systematically check each component or data flow against these categories.

- Advantages:

- A straightforward mnemonic to ensure common threat types are not missed.
- Particularly useful in brainstorming sessions and checklists.

- Disadvantages:

- Might overlook new or unusual threat types not encapsulated by these six categories.
- Less architectural detail than the Diagram-Driven approach.

4. **Insider vs. Outsider Threats**

Key Points:

- **Insiders** are individuals with legitimate access (e.g., employees, contractors) who can misuse that access. They often pose a greater risk because they know internal systems, processes, and vulnerabilities.
- **Outsiders** have to breach perimeter defenses (firewalls,

authentication), so they may be more limited initially but can still launch sophisticated attacks (e.g., phishing, malware).

- **Security Measures:**

- For **insiders**: Strict access controls, monitoring and logging, separation of duties, regular audits.
- For **outsiders**: Firewalls, intrusion detection, strong external authentication, network segmentation.

Sample Conclusion: "Although both outsiders and insiders pose serious threats, insiders can be more dangerous due to their intimate knowledge of the organization's systems and data. Therefore, robust internal controls, user access reviews, and monitoring are crucial in mitigating the risks posed by individuals already within the network perimeter."

5. **Model-Reality Gaps**

Key Points:

- Security models can fail when they rely on assumptions that do not hold in real-world situations (e.g., trusting a third-party cloud service to always implement strong encryption or monitoring).
- In a **cloud service** context, an organization might assume the cloud provider enforces top-tier security measures. If the provider's internal policies or security settings are weaker than expected, this mismatch leads to a gap.
- **Strategy to Mitigate:** Regular audits, verifying logs, third-party penetration tests, and establishing clear **Service-Level Agreements (SLAs)** that detail security responsibilities and requirements.

Sample Answer: "In a cloud service scenario, companies often assume their data is fully protected by the provider's security controls. However, if the cloud provider does not enforce strong tenant isolation, or if multi-tenant vulnerabilities exist, attackers could pivot between different cloud tenants. To mitigate such gaps, organizations should perform due diligence by reviewing security certifications of their provider, requesting audit reports, and conducting periodic penetration tests."

Part C

1. Applying the Risk Equation

A company's internal application has:

- $T = 0.02$ (2% probability per year)
- $V = 0.7$ (70% success chance if attacked)
- $C = €5,000,000$

(a) Calculate $R = T \times V \times C$

$$R = 0.02 \times 0.7 \times 5,000,000$$

$$R = 0.014 \times 5,000,000$$

$$R = €70,000$$

Thus, the **annual risk** is €70,000.

(b) Discuss two ways to reduce (R)

1. Technical:

- Implement stricter access controls, regular patching, and advanced intrusion detection systems to reduce the **vulnerability** (V).
- Encrypt sensitive data and limit user privileges to prevent successful exploitation.

2. Procedural:

- Provide employee security awareness training to lower the chance of successful phishing or social engineering (this can reduce the *effective* threat and/or vulnerability).
- Have a solid incident response plan, ensuring quick detection and recovery to minimize the **cost** (C) of a successful breach (e.g., backups, disaster recovery).

2. Comparing Security Controls

A university has:

- Original values:

- $T = 0.1$
- $V = 0.8$
- $C = €2,000,000$

- **Option A:** Improves firewalls, reducing V to 0.3 (keeping $T = 0.1$).

- **Option B:** Intrusion detection + staff training, reducing T to 0.02 (keeping $V = 0.8$).

- Option A: New risk R_A

$$R_A = T \times V_{\text{new}} \times C = 0.1 \times 0.3 \times 2,000,000 = 0.03 \times 2,000,000 = €60,000$$

- **Option B: New risk (R_B)** $R_B = T_{\text{new}} \times V \times C = 0.02 \times 0.8 \times 2,000,000 = 0.016 \times 2,000,000 = \text{€}32,000$
- **Which is lower & Recommendation?**
 - Option **B** yields **€32,000** annual risk, which is lower than Option **A** at **€60,000**.
 - If both options cost the same, **Option B** appears more cost-effective since it reduces the overall risk more significantly. Additionally, improved staff training has long-term benefits (e.g., fewer security incidents overall).